

DPDP COMPLIANCE AUDIT

MLPredict

Digital Personal Data Protection Act 2023

96/100

Grade A

Strong

Scanned: 25 March 2026

Files indexed: 1

Languages: Flask, numpy, pandas, pickle

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

No personally identifiable information (PII) is explicitly collected or stored in this codebase. The primary risk surface relates to the potential for sensitive input data to be processed by the model, though this data is not identified as PII.

Validation Summary Rule findings: 5 confirmed, 1 false positives suppressed • AI gaps: 1 dual-validated • Score: 96 (rules) → 96 (integrated)

Total findings: 6

HIGH: 1

MEDIUM: 2

INFO: 3

Tech Stack: Flask, numpy, pandas, pickle

Risk Profile: No personally identifiable information (PII) is explicitly collected or stored in this codebase. The primary risk surface relates to the potential for sensitive input data to be processed by the model, though this data is not identified as PII.

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	22/22 (100%)	PASS
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	18/18 (100%)	PASS
Section 8	10	10/10 (100%)	PASS
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	8/8 (100%)	PASS
Section 8(6)	8	4.0/8 (50%)	WARN
Section 9	6	6/6 (100%)	PASS
Section 11	6	6/6 (100%)	PASS
Section 16	4	4/4 (100%)	PASS
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal	4	4/4 (100%)	PASS

Estimated Total Remediation Effort: 1.0–3.8 engineering days

Rule	Section	Severity	File
NO_LOGGING_DETECTED	Section 8(6) — Breach	MEDIUM	N/A
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A
NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
NO_CROSS_BORDER_DETECTED	Section 16 — Cross-Border Transfer	INFO	N/A
DEBUG_MODE_ENABLED	Section 8(1) — Security	HIGH	app.py
	Section 8(4) Audit Trail	MEDIUM	

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (4–16 hours)

Fix immediately — these represent the highest legal exposure.

- Debug Mode Enabled — app.py (4–16 hrs)

Week 2 — High Priority (4–14 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- No Logging Detected (2–6 hrs)
- (2–8 hrs)

Total estimated remediation effort: 8–30 hours (1.0–3.8 engineering days)

Details

Finding 1 of 6

[Section 8(6) — Breach]

1. [MEDIUM] NO_LOGGING_DETECTED — N / A

Estimated fix time: 2–6 hours

No logging library detected anywhere. Breach detection and reporting may be inadequate.

Risk:

The absence of logging makes it difficult to detect, investigate, and report security incidents or data breaches as required by the DPDP Act.

Fix:

1. Integrate a logging library (e.g., Python's built-in `logging` module) to record application events, errors, and security-relevant information.
2. Configure log levels and handlers to direct logs to appropriate destinations (e.g., files, centralized logging system).
3. Implement logging for key operations, including data access, user authentication, and error handling.

DPDP:

Section 8(6) — Appropriate measures must be in place for breach detection and reporting.

Example:

```
import logging
logging.basicConfig(level=logging.INFO, format='%(asctime)s - %(levelname)s - %(message)s')
@app.route('/predict', methods=['POST'])
def predict():
    try:
        # ... prediction logic ...
        logging.info(f"Prediction successful for features: {features}")
        return render_template("index.html", prediction_text=f"Predicted House Price: ${output}K")
    except Exception as e:
        logging.error(f"Error during prediction: {e}", exc_info=True)
        return render_template("index.html", prediction_text="Error: " + str(e))
```

Finding 2 of 6

[Section 5 — Notice]

2. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 3 of 6

[Section 5 — Purpose Limitation]

3. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 4 of 6

[Section 16 — Cross-Border Transfer]

4. [INFO] NO_CROSS_BORDER_DETECTED — N / A

No foreign cloud or non-India region config detected.

Finding 5 of 6

[Section 8(1) — Security]

5. [HIGH] DEBUG_MODE_ENABLED — app.py:38**Evidence snippet:** `app.run(debug=True)`**Estimated fix time:** 4–16 hours

Debug mode is enabled. In production, this exposes interactive debuggers (Flask/Werkzeug), detailed stack traces, and internal system information to users. Flask debug mode specifically allows arbitrary code execution via the Werkzeug console. DPDP Section 8(1) requires appropriate security measures to protect personal data.

Risk:

Debug mode enabled in production exposes sensitive system information and potential vulnerabilities, increasing the risk of unauthorized access or data breaches.

Fix:

1. Set `debug=False` in `app.run()` or remove the `debug=True` argument entirely when deploying to production.

DPDP:

Section 8(1) — Security measures must be implemented to protect personal data.

Example:

```
if __name__ == "__main__": # Ensure debug is False in production environments
    app.run(debug=False)
```

Finding 6 of 6

[Section 8(4) Audit Trail]

6. [MEDIUM] — CODEBASE-WIDE

Lack of audit trail for data access

AI-Identified Compliance Gaps

The following gaps were identified by AI analysis and cross-validated. These are advisory observations, not verified rule violations. Human review is required before acting on these findings.

[AI-INFERRED] Lack of audit trail for data access

Confidence: 55%

Section 8(4) Audit Trail

The `app.py` file processes user input features for model prediction via POST /predict and renders predictions via GET /. While the repository context states no PII is explicitly collected, any sensitive data processed by the model could be considered personal data. There is no evidence of logging or auditing access to this data.

Recommendation: Implement logging in `app.py` to record when user input features are processed and when model predictions are generated, including timestamps and a unique identifier for the request.